

FixProof · Video III evidence appendix

Prepared September 22, 2026 from verified saved evidence. This is a reference handout, not a new experiment or a replacement for the frozen primary report. It includes all 15 candidate-level outcomes and the *complete recorded text* of every original and later human rationale.

15 primary attempts

Five initial calls per controlled CWE fixture

10 original reviews

Seven acceptances; three additional-testing requests

14 supplemental human records

5 reject · 5 bounded accept · 4 request more testing

How to read this: “Ready for review” is an automated state, not a human approval. Supplemental security, behavioral parity, and robustness are different criteria and must not be pooled into one repair-success rate. A supplemental human record may be the first human decision for SQLi or a later qualification of an earlier review; it never overwrites primary-v1.

1. Frozen primary-v1 matrix

Candidate	Target SAST	Security pass	Functional pass	Automated state	Original human	Supplemental human
XSS 01	persistent	4/4	6/6	Needs adjudication	Accept candidate	Reject candidate
XSS 02	persistent	4/4	6/6	Needs adjudication	Accept candidate	Reject candidate
XSS 03	persistent	4/4	6/6	Needs adjudication	Accept candidate	No supplemental result
XSS 04	persistent	4/4	6/6	Needs adjudication	Request more testing	Reject candidate
XSS 05	persistent	4/4	6/6	Needs adjudication	Request more testing	Reject candidate
SQLi 01	resolved	2/2	3/3	Ready for review	No human result	Bounded accept
SQLi 02	resolved	2/2	3/3	Ready for review	No human result	Bounded accept
SQLi 03	resolved	2/2	3/3	Ready for review	No human result	Bounded accept
SQLi 04	resolved	2/2	3/3	Ready for review	No human result	Bounded accept
SQLi 05	resolved	2/2	3/3	Ready for review	No human result	Bounded accept
Traversal 01	persistent	2/2	3/3	Needs adjudication	Request more testing	Reject candidate
Traversal 02	persistent	2/2	3/3	Needs adjudication	Accept candidate	Request more testing

Candidate	Target SAST	Security pass	Functional pass	Automated state	Original human	Supplemental human
Traversal 03	persistent	2/2	3/3	Needs adjudication	Accept candidate	Request more testing
Traversal 04	persistent	2/2	3/3	Needs adjudication	Accept candidate	Request more testing
Traversal 05	persistent	2/2	3/3	Needs adjudication	Accept candidate	Request more testing

Primary security and functional columns are passed/registered checks from the original suite. Every one of the 15 candidates passed those fixed suites. Five target SAST findings resolved; ten persisted while runtime checks passed. The five SQLi candidates had no original primary human verdict; their bounded acceptances are separate September 22 supplemental human records.

2. Supplemental-v1 matrix — same 15 saved candidates

The supplemental protocol first characterized three baselines, then ran registered cases against the saved candidates in disposable copies. It made no new model calls and did not rerun primary SAST.

Security
55 pass · 0 fail · 5 inconclusive

Behavioral parity
40 pass · 5 fail · 0 inconclusive

Robustness
25 pass · 10 fail · 0 inconclusive

P/F/I means pass/fail/inconclusive. Nonpassing case IDs identify failures or unexecuted cases; they are not interchangeable. `PATH-S06` was inconclusive because the Windows symlink fixture could not be created.

Candidate	Security P/F/I	Parity P/F/I	Robustness P/F/I	Nonpassing registered cases	Supplemental human
XSS 01	3/0/0	4/1/0	1/0/0	XSS-P01 (fail)	Reject candidate
XSS 02	3/0/0	4/1/0	1/0/0	XSS-P01 (fail)	Reject candidate
XSS 03	3/0/0	5/0/0	1/0/0	None in registered supplement	No supplemental result
XSS 04	3/0/0	4/1/0	1/0/0	XSS-P01 (fail)	Reject candidate
XSS 05	3/0/0	4/1/0	1/0/0	XSS-P01 (fail)	Reject candidate
SQLi 01	3/0/0	2/0/0	2/1/0	SQL-R01 (fail)	Bounded accept
SQLi 02	3/0/0	2/0/0	2/1/0	SQL-R01 (fail)	Bounded accept
SQLi 03	3/0/0	2/0/0	2/1/0	SQL-R01 (fail)	Bounded accept
SQLi 04	3/0/0	2/0/0	2/1/0	SQL-R01 (fail)	Bounded accept
SQLi 05	3/0/0	2/0/0	2/1/0	SQL-R01 (fail)	Bounded accept
Traversal 01	5/0/1	1/1/0	2/1/0	PATH-P01 (fail), PATH-R03 (fail), PATH-S06 (inconclusive)	Reject candidate
Traversal 02	5/0/1	2/0/0	3/0/0	PATH-S06 (inconclusive)	Request more testing
Traversal 03	5/0/1	2/0/0	0/3/0	PATH-R01 (fail), PATH-R02 (fail), PATH-R03 (fail), PATH-S06 (inconclusive)	Request more testing
Traversal 04	5/0/1	2/0/0	3/0/0	PATH-S06 (inconclusive)	Request more testing

Candidate	Security P/F/I	Parity P/F/I	Robustness P/F/I	Nonpassing registered cases	Supplemental human
Traversal 05	5/0/1	2/0/0	2/1/0	PATH-R03 (fail), PATH-S06 (inconclusive)	Request more testing

XSS 01, 02, 04, and 05 each failed the frozen missing-name parity case `XSS-P01`; XSS 03 passed all nine registered XSS supplemental cases. SQLi `SQL-R01` remains failed even though the bounded repair was accepted; it is a new repeated-parameter robustness requirement, not a retroactive primary security failure. Traversal 02–05 request more testing, and their symlink observations remain inconclusive—not passes.

3. Complete human rationale records

Text below is copied verbatim from bound `result.json` rationale fields, including original primary review wording and separate supplemental human decisions. The source path and recorded timestamp accompany each statement. The five SQLi entries have no original primary human result; their September 22 bounded acceptances are shown separately and were not inferred automatically from `READY\_FOR\_HUMAN\_REVIEW`.

XSS 01 · CWE-79 · primary-v1-xss-initial-01

Primary target SAST: persistent; automated state: NEEDS_HUMAN_ADJUDICATION. Supplemental cases: 8 pass, 1 fail, 0 inconclusive. Nonpassing: XSS-P01 (fail).

Primary decision: data/primary_trials/v1/cases/xss/attempt-01/decision.json
Supplemental candidate result: data/supplemental/v1/runs/20260914T192749827554Z-candidates-xss/attempt-01/result.json

Original primary human review — ACCEPT_CANDIDATE

Reviewer: Tony Tran · Recorded: 2026-09-05T14:35:49.364498Z
Source: data/primary_reviews/v1/primary-v1-xss-initial-01/result.json

escapeHTML encodes HTML sensitive characters include /

Supplemental human review — FOLLOW_UP_REJECT_CANDIDATE

Reviewer: Tony Tran · Recorded: 2026-09-21T19:47:18.597923Z
Source: data/supplemental/v1/follow-up-reviews/primary-v1-xss-initial-01/result.json

I reviewed the candidate patch, original decision, and all nine supplemental outcomes. The candidate passed all three registered supplemental security cases and the robustness case. However, XSS-P01 omitted the name parameter and observed "<h1>Hello </h1>" instead of the frozen baseline "<h1>Hello undefined</h1>". The expression String(value ?? "") converts the missing value to an empty string. Because the frozen protocol requires exact behavioral parity for this case, I reject the candidate for the bounded benchmark. This is a behavioral-parity decision and does not mean that the registered XSS attacks remained exploitable.

XSS 02 · CWE-79 · primary-v1-xss-initial-02

Primary target SAST: persistent; automated state: NEEDS_HUMAN_ADJUDICATION. Supplemental cases: 8 pass, 1 fail, 0 inconclusive. Nonpassing: XSS-P01 (fail).

Primary decision: data/primary_trials/v1/cases/xss/attempt-02/decision.json

Supplemental candidate result: data/supplemental/v1/runs/20260914T192749827554Z-candidates-xss/attempt-02/result.json

Original primary human review — ACCEPT_CANDIDATE

Reviewer: Tony Tran · Recorded: 2026-09-05T15:46:57.091307Z

Source: data/primary_reviews/v1/primary-v1-xss-initial-02/result.json

Implemented safeName that holds global replacement map encodes &<>"

Supplemental human review — FOLLOW_UP_REJECT_CANDIDATE

Reviewer: Tony Tran · Recorded: 2026-09-21T19:47:18.760119Z

Source: data/supplemental/v1/follow-up-reviews/primary-v1-xss-initial-02/result.json

I reviewed the candidate patch, original decision, and all nine supplemental outcomes. The candidate passed all three registered supplemental security cases and the robustness case. However, XSS-P01 omitted the name parameter and observed "<h1>Hello </h1>" instead of the frozen baseline "<h1>Hello undefined</h1>". The expression String(name ?? "") converts the missing value to an empty string. Because the frozen protocol requires exact behavioral parity for this case, I reject the candidate for the bounded benchmark. This is a behavioral-parity decision and does not mean that the registered XSS attacks remained exploitable.

XSS 03 · CWE-79 · primary-v1-xss-initial-03

Primary target SAST: persistent; automated state: NEEDS_HUMAN_ADJUDICATION. Supplemental cases: 9 pass, 0 fail, 0 inconclusive. Nonpassing: None in registered supplement.

Primary decision: data/primary_trials/v1/cases/xss/attempt-03/decision.json

Supplemental candidate result: data/supplemental/v1/runs/20260914T192749827554Z-candidates-xss/attempt-03/result.json

Original primary human review — ACCEPT_CANDIDATE

Reviewer: Tony Tran · Recorded: 2026-09-10T17:30:47.656470Z

Source: data/primary_reviews/v1/primary-v1-xss-initial-03/result.json

Patch change: >-
req.query.name enters the /hello handler and is assigned to name. Originally, it was concatenated directly into an HTML response. The candidate adds a local escapeHtml function that converts the value to a string and encodes &, <, >, double quotes, single quotes, and backticks before res.send. The route still returns an <h1>Hello [name]</h1> greeting. Its wire-format changes for special characters, but the browser-visible text is preserved. The patch assumes name is plain text rather than intentionally supplied HTML, and that the escaped value remains in HTML element-content context. String(undefined) also preserves the original missing-name result, "undefined".

Security observations: >-
All four requests returned 200. The script-tag payload was returned as <script>...; the img/onerror payload had its markup delimiters encoded; the quote-plus-SVG payload encoded both the quote and markup delimiters; and the consecutive-markup payload encoded every relevant < and >. In every case, the raw response contained no executable version of the supplied markup and headless Chromium reported no dialogs or payload execution. These tests establish protection against the four tested reflected-XSS forms in the current HTML element-content sink, but they are a fixed payload suite rather than a general proof for every input or future output context.

Functional observations: >-
Tony and Tony Tran were returned unchanged. Inputs containing &, <, adjacent &<>, and "><hello> were entity-encoded in the HTTP body but decoded to exactly the original browser-visible value. That expected behavior makes sense for a greeting route where a name is text, not markup. The tests therefore show that the patch does not strip or corrupt the tested special characters while neutralizing their HTML syntax.

Why the SAST warning may persist: >-
Both CWE-79 rules now point to candidate line 17, where res.send receives

"<h1>Hello " + escapeHtml(name) + "</h1>". One rule conservatively detects user data in manually constructed HTML, and the other detects user input written directly to a response. Neither appears to recognize the custom escapeHtml helper as a trusted, context-appropriate sanitizer. Because the warning is located at the post-escaping sink, while code inspection and both response and browser evidence show effective encoding, the persistence most likely reflects a scanner modeling limitation rather than an ineffective repair.

Remaining uncertainty or additional test needed: >-

The existing suite does not cover empty or omitted name values, repeated query parameters, Unicode, entity-looking input such as <script>, single quotes, or backticks. It also detects execution primarily through alert dialogs. An optional stronger supplemental test would exercise those values and assert that the resulting h1 contains only one text node, has no attacker-created child elements, and displays the original input exactly. A property/fuzz test over arbitrary strings would provide broader assurance. This uncertainty does not reveal a concrete bypass in the present sink, because the implementation encodes ampersands before encoding every < delimiter.

Proposed verdict and justification: >-

ACCEPT_CANDIDATE within the controlled /hello-route scope. The patch applies correct HTML element-content encoding before the only response sink, preserves the route's intended visible greeting for the tested normal and special inputs, introduces no new SAST findings, and retains the original missing-name coercion behavior. The persistent scanner finding is best explained by lack of recognition of the local escaping helper. Acceptance would not imply that the helper is safe if its output is later reused in an attribute, URL, JavaScript, CSS, or another context.

No separate supplemental human verdict or rationale is recorded.

XSS 04 · CWE-79 · primary-v1-xss-initial-04

Primary target SAST: persistent; automated state: NEEDS_HUMAN_ADJUDICATION. Supplemental cases: 8 pass, 1 fail, 0 inconclusive. Nonpassing: XSS-P01 (fail).

Primary decision: data/primary_trials/v1/cases/xss/attempt-04/decision.json
Supplemental candidate result: data/supplemental/v1/runs/20260914T192749827554Z-candidates-xss/attempt-04/result.json

Original primary human review — REQUEST_ADDITIONAL_TESTING

Reviewer: Tony Tran · Recorded: 2026-09-12T15:35:04.137400Z
Source: data/primary_reviews/v1/primary-v1-xss-initial-04/result.json

The candidate encodes HTML metacharacters before reflection. All four recorded payloads were returned as encoded text and did not execute in Chromium, all six functional cases passed, and no new SAST findings appeared. However, the candidate changes a missing name from the original text "undefined" to an empty string, and the frozen suite does not cover missing, empty, repeated, entity-looking, Unicode, single-quote, or backtick inputs or DOM structure. I am requesting supplemental testing before deciding whether to accept or reject the candidate. The persistent SAST warning alone does not establish that the candidate remains exploitable.

Supplemental human review — FOLLOW_UP_REJECT_CANDIDATE

Reviewer: Tony Tran · Recorded: 2026-09-15T19:58:42.353608Z
Source: data/supplemental/v1/follow-up-reviews/primary-v1-xss-initial-04/result.json

I reviewed the candidate patch, original review, and all nine supplemental XSS results. I also confirmed that the September 15 rerun produced the same outcome. Attempt 04 passed all three supplemental security tests and the robustness test. However, XSS-P01 demonstrated that an omitted name changed from the baseline text "Hello undefined" to "Hello ". Because the frozen protocol requires exact observable behavior for this case, I reject the candidate for the bounded benchmark. This is a functional-parity decision and does not mean the registered XSS attacks remained exploitable. Reference: "XSS-P01"

XSS 05 · CWE-79 · primary-v1-xss-initial-05

Primary target SAST: persistent; automated state: NEEDS_HUMAN_ADJUDICATION. Supplemental cases: 8 pass, 1 fail, 0 inconclusive. Nonpassing: XSS-P01 (fail).

Primary decision: data/primary_trials/v1/cases/xss/attempt-05/decision.json
Supplemental candidate result: data/supplemental/v1/runs/20260914T192749827554Z-candidates-xss/attempt-05/result.json

Original primary human review — REQUEST_ADDITIONAL_TESTING

Reviewer: Tony Tran · Recorded: 2026-09-12T15:39:39.365820Z
Source: data/primary_reviews/v1/primary-v1-xss-initial-05/result.json

Verified that all security/function test cases passed. However, the "String(name ?? "")" converts from "undefined" to an empty string. Therefore, additional testing needed.

Supplemental human review — FOLLOW_UP_REJECT_CANDIDATE

Reviewer: Tony Tran · Recorded: 2026-09-15T17:38:05.564228Z
Source: data/supplemental/v1/follow-up-reviews/primary-v1-xss-initial-05/result.json

I reviewed the candidate patch, the original review, and all nine supplemental XSS results. I also reproduced the supplemental evaluation on September 15 with the same outcome. Attempt 05 passed all three security tests and the robustness test, but XSS-P01 confirmed that an omitted name changed from the baseline “Hello undefined” to “Hello ”. Because the frozen protocol requires exact observable behavior for this case, I reject the candidate for the bounded benchmark. This is a functional-parity decision and does not mean the registered XSS attacks remained exploitable.

SQLi 01 · CWE-89 · primary-v1-sqli-initial-01

Primary target SAST: resolved; automated state: READY_FOR_HUMAN_REVIEW. Supplemental cases: 7 pass, 1 fail, 0 inconclusive. Nonpassing: SQL-R01 (fail).

Primary decision: data/primary_trials/v1/cases/sqli/attempt-01/decision.json

Supplemental candidate result: data/supplemental/v1/runs/20260914T192901912061Z-candidates-sqli/attempt-01/result.json

No original human verdict or rationale is recorded. The automated state was readiness for human review, not approval.

Supplemental human review — FOLLOW_UP_ACCEPT_CANDIDATE

Reviewer: Tony Tran · Recorded: 2026-09-22T20:29:44.150061Z

Source: data/supplemental/v1/follow-up-reviews/primary-v1-sqli-initial-01/result.json

I reviewed the candidate patch, automated primary decision, and all eight supplemental outcomes for this candidate. The patch replaces SQL string concatenation with a parameterized query. The primary target SAST finding resolved, and the candidate passed the original security and functional checks. In the supplement, it passed all three registered SQL-injection security cases, both behavioral-parity cases, and two of three robustness cases. SQL-R01 supplied repeated username parameters and returned HTTP 200 with an empty array instead of the registered HTTP 400 JSON error, so that robustness result remains failed. The response returned no user row and did not broaden the query result. Under my bounded criterion, this client-visible status-code difference is not severe enough to reject the tested SQL-injection repair. I accept the candidate for the bounded benchmark while explicitly retaining the SQL-R01 limitation. This is not full supplemental conformance or production approval, and it does not alter the primary record or metrics.

SQLi 02 · CWE-89 · primary-v1-sqli-initial-02

Primary target SAST: resolved; automated state: READY_FOR_HUMAN_REVIEW. Supplemental cases: 7 pass, 1 fail, 0 inconclusive. Nonpassing: SQL-R01 (fail).

Primary decision: data/primary_trials/v1/cases/sqli/attempt-02/decision.json

Supplemental candidate result: data/supplemental/v1/runs/20260914T192901912061Z-candidates-sqli/attempt-02/result.json

No original human verdict or rationale is recorded. The automated state was readiness for human review, not approval.

Supplemental human review — FOLLOW_UP_ACCEPT_CANDIDATE

Reviewer: Tony Tran · Recorded: 2026-09-22T20:29:44.170424Z

Source: data/supplemental/v1/follow-up-reviews/primary-v1-sqli-initial-02/result.json

I reviewed the candidate patch, automated primary decision, and all eight supplemental outcomes for this candidate. The patch replaces SQL string concatenation with a parameterized query. The primary target SAST finding resolved, and the candidate passed the original security and functional checks. In the supplement, it passed all three registered SQL-injection security cases, both behavioral-parity cases, and two of three robustness cases. SQL-R01 supplied repeated username parameters and returned HTTP 200 with an empty array instead of the registered HTTP 400 JSON error, so that robustness result remains failed. The response returned no user row and did not broaden the query result. Under my bounded criterion, this client-visible status-code difference is not severe enough to reject the tested SQL-injection repair. I accept the candidate for the bounded benchmark while explicitly retaining the SQL-R01 limitation. This is not full supplemental conformance or production approval, and it does not alter the primary record or metrics.

SQLi 03 · CWE-89 · primary-v1-sqli-initial-03

Primary target SAST: resolved; automated state: READY_FOR_HUMAN_REVIEW. Supplemental cases: 7 pass, 1 fail, 0 inconclusive. Nonpassing: SQL-R01 (fail).

Primary decision: data/primary_trials/v1/cases/sqli/attempt-03/decision.json

Supplemental candidate result: data/supplemental/v1/runs/20260914T192901912061Z-candidates-sqli/attempt-03/result.json

No original human verdict or rationale is recorded. The automated state was readiness for human review, not approval.

Supplemental human review — FOLLOW_UP_ACCEPT_CANDIDATE

Reviewer: Tony Tran · Recorded: 2026-09-22T20:29:44.191739Z

Source: data/supplemental/v1/follow-up-reviews/primary-v1-sqli-initial-03/result.json

I reviewed the candidate patch, automated primary decision, and all eight supplemental outcomes for this candidate. The patch replaces SQL string concatenation with a parameterized query. The primary target SAST finding resolved, and the candidate passed the original security and functional checks. In the supplement, it passed all three registered SQL-injection security cases, both behavioral-parity cases, and two of three robustness cases. SQL-R01 supplied repeated username parameters and returned HTTP 200 with an empty array instead of the registered HTTP 400 JSON error, so that robustness result remains failed. The response returned no user row and did not broaden the query result. Under my bounded criterion, this client-visible status-code difference is not severe enough to reject the tested SQL-injection repair. I accept the candidate for the bounded benchmark while explicitly retaining the SQL-R01 limitation. This is not full supplemental conformance or production approval, and it does not alter the primary record or metrics.

SQLi 04 · CWE-89 · primary-v1-sqli-initial-04

Primary target SAST: resolved; automated state: READY_FOR_HUMAN_REVIEW. Supplemental cases: 7 pass, 1 fail, 0 inconclusive. Nonpassing: SQL-R01 (fail).

Primary decision: data/primary_trials/v1/cases/sqli/attempt-04/decision.json

Supplemental candidate result: data/supplemental/v1/runs/20260914T192901912061Z-candidates-sqli/attempt-04/result.json

No original human verdict or rationale is recorded. The automated state was readiness for human review, not approval.

Supplemental human review — FOLLOW_UP_ACCEPT_CANDIDATE

Reviewer: Tony Tran · Recorded: 2026-09-22T20:29:44.209902Z

Source: data/supplemental/v1/follow-up-reviews/primary-v1-sqli-initial-04/result.json

I reviewed the candidate patch, automated primary decision, and all eight supplemental outcomes for this candidate. The patch replaces SQL string concatenation with a parameterized query. The primary target SAST finding resolved, and the candidate passed the original security and functional checks. In the supplement, it passed all three registered SQL-injection security cases, both behavioral-parity cases, and two of three robustness cases. SQL-R01 supplied repeated username parameters and returned HTTP 200 with an empty array instead of the registered HTTP 400 JSON error, so that robustness result remains failed. The response returned no user row and did not broaden the query result. Under my bounded criterion, this client-visible status-code difference is not severe enough to reject the tested SQL-injection repair. I accept the candidate for the bounded benchmark while explicitly retaining the SQL-R01 limitation. This is not full supplemental conformance or production approval, and it does not alter the primary record or metrics.

SQLi 05 · CWE-89 · primary-v1-sqli-initial-05

Primary target SAST: resolved; automated state: READY_FOR_HUMAN_REVIEW. Supplemental cases: 7 pass, 1 fail, 0 inconclusive. Nonpassing: SQL-R01 (fail).

Primary decision: data/primary_trials/v1/cases/sqli/attempt-05/decision.json

Supplemental candidate result: data/supplemental/v1/runs/20260914T192901912061Z-candidates-sqli/attempt-05/result.json

No original human verdict or rationale is recorded. The automated state was readiness for human review, not approval.

Supplemental human review — FOLLOW_UP_ACCEPT_CANDIDATE

Reviewer: Tony Tran · Recorded: 2026-09-22T20:29:44.228929Z

Source: data/supplemental/v1/follow-up-reviews/primary-v1-sqli-initial-05/result.json

I reviewed the candidate patch, automated primary decision, and all eight supplemental outcomes for this candidate. The patch replaces SQL string concatenation with a parameterized query. The primary target SAST finding resolved, and the candidate passed the original security and functional checks. In the supplement, it passed all three registered SQL-injection security cases, both behavioral-parity cases, and two of three robustness cases. SQL-R01 supplied repeated username parameters and returned HTTP 200 with an empty array instead of the registered HTTP 400 JSON error, so that robustness result remains failed. The response returned no user row and did not broaden the query result. Under my bounded criterion, this client-visible status-code difference is not severe enough to reject the tested SQL-injection repair. I accept the candidate for the bounded benchmark while explicitly retaining the SQL-R01 limitation. This is not full supplemental conformance or production approval, and it does not alter the primary record or metrics.

Traversal 01 · CWE-22 · primary-v1-path-traversal-initial-01

Primary target SAST: persistent; automated state: NEEDS_HUMAN_ADJUDICATION. Supplemental cases: 8 pass, 2 fail, 1 inconclusive. Nonpassing: PATH-P01 (fail), PATH-R03 (fail), PATH-S06 (inconclusive).

Primary decision: data/primary_trials/v1/cases/path-traversal/attempt-01/decision.json
Supplemental candidate result: data/supplemental/v1/runs/20260914T192827434537Z-candidates-path-traversal/attempt-01/result.json

Original primary human review — REQUEST_ADDITIONAL_TESTING

Reviewer: Tony Tran · Recorded: 2026-09-12T16:02:20.253967Z
Source: data/primary_reviews/v1/primary-v1-path-traversal-initial-01/result.json

Additional testing needed: The candidate resolves the configured file root and requested path, computes the relative path, and rejects missing, absolute, or parent-relative paths. The recorded legitimate-file control and parent-directory attack both passed, all three functional cases passed, and no new SAST findings appeared. However, the target SAST finding remains persistent, and the security suite tests only one traversal payload. The condition `rel.startsWith("..")` could also reject a permitted in-root filename beginning with two dots, such as `..notes.txt`, although this was not demonstrated by the frozen fixtures. Encoded traversal, repeated query parameters, absolute paths, Windows and POSIX separators, sibling-prefix boundaries, and symlink behavior remain untested. I am requesting supplemental testing before accepting or rejecting the candidate. The persistent SAST warning alone does not establish that the candidate remains exploitable.

Supplemental human review — FOLLOW_UP_REJECT_CANDIDATE

Reviewer: Tony Tran · Recorded: 2026-09-15T21:24:25.437996Z
Source: data/supplemental/v1/follow-up-reviews/primary-v1-path-traversal-initial-01/result.json

I reviewed the candidate patch, original review, and all eleven supplemental traversal results. The candidate passed all five executable security cases, while PATH-S06 remained inconclusive because Windows could not create the required symlink fixture. PATH-P01 confirmed that the candidate rejects the valid in-root filename `"..notes.txt"`, and PATH-R03 returned HTTP 404 rather than the predefined HTTP 400 response for repeated filenames. These results demonstrate a behavioral-parity failure and a robustness-contract failure. I reject the candidate for the bounded benchmark while preserving the symlink result as inconclusive.

Traversal 02 · CWE-22 · primary-v1-path-traversal-initial-02

Primary target SAST: persistent; automated state: NEEDS_HUMAN_ADJUDICATION. Supplemental cases: 10 pass, 0 fail, 1 inconclusive. Nonpassing: PATH-S06 (inconclusive).

Primary decision: data/primary_trials/v1/cases/path-traversal/attempt-02/decision.json

Supplemental candidate result: data/supplemental/v1/runs/20260914T192827434537Z-candidates-path-traversal/attempt-02/result.json

Original primary human review — ACCEPT_CANDIDATE

Reviewer: Tony Tran · Recorded: 2026-09-12T16:12:46.607263Z

Source: data/primary_reviews/v1/primary-v1-path-traversal-initial-02/result.json

ACCEPT-CANDIDATE: The candidate requires the file name to be a nonempty string, resolves the configured root and requested path, and permits the read only when the resolved path equals the root or begins with the root plus the platform path separator. Using the separator boundary prevents a sibling directory with a similar prefix from being treated as inside the permitted root. The recorded legitimate-file control and parent-traversal attack passed, all three functional cases passed, syntax validation passed, and no new SAST findings appeared. The persistent CWE-22 warnings point to user input entering path.resolve and appear not to account for the subsequent containment guard; the warning alone does not demonstrate a working bypass. I accept the candidate within the controlled /file benchmark scope. This does not establish protection against symlink escapes, every encoding form, repeated query parameters, or every operating-system path behavior, which remain appropriate supplemental tests.

Supplemental human review — FOLLOW_UP_REQUEST_MORE_TESTING

Reviewer: Tony Tran · Recorded: 2026-09-22T20:29:44.248756Z

Source: data/supplemental/v1/follow-up-reviews/primary-v1-path-traversal-initial-02/result.json

I reviewed the candidate patch, original acceptance, and all eleven supplemental traversal outcomes. The candidate passed both behavioral-parity cases, all three robustness cases, and all five executable security cases. PATH-S06 remains inconclusive because the Windows environment could not create the required symlink or junction fixture. The patch enforces a lexical resolved-root boundary, but the saved evidence does not establish containment of a filesystem target reached through an in-root link. I therefore request more testing in a symlink-capable environment rather than claiming complete traversal protection. This later conclusion preserves the original bounded acceptance, the inconclusive result, and all primary metrics.

Traversal 03 · CWE-22 · primary-v1-path-traversal-initial-03

Primary target SAST: persistent; automated state: NEEDS_HUMAN_ADJUDICATION. Supplemental cases: 7 pass, 3 fail, 1 inconclusive. Nonpassing: PATH-R01 (fail), PATH-R02 (fail), PATH-R03 (fail), PATH-S06 (inconclusive).

Primary decision: data/primary_trials/v1/cases/path-traversal/attempt-03/decision.json

Supplemental candidate result: data/supplemental/v1/runs/20260914T192827434537Z-candidates-path-traversal/attempt-03/result.json

Original primary human review — ACCEPT_CANDIDATE

Reviewer: Tony Tran · Recorded: 2026-09-12T19:56:38.231012Z

Source: data/primary_reviews/v1/primary-v1-path-traversal-initial-03/result.json

After reviewing the patch and results, I confirmed that the candidate resolves the allowed root and requested path and checks that the final path stays inside the public-files directory. The valid-file control passed, the recorded parent-traversal attack was blocked, all three functional tests passed, syntax passed, and no new SAST findings appeared. The CWE-22 warning still points to path.resolve, but it does not appear to account for the containment check that follows it. I accept this candidate for the controlled /file test case. More testing would still be useful for missing or repeated query values, encoded paths, Windows and POSIX differences, and symlinks, so this acceptance is not a production-security claim.

Supplemental human review — FOLLOW_UP_REQUEST_MORE_TESTING

Reviewer: Tony Tran · Recorded: 2026-09-22T20:29:44.265893Z

Source: data/supplemental/v1/follow-up-reviews/primary-v1-path-traversal-initial-03/result.json

I reviewed the candidate patch, original acceptance, and all eleven supplemental traversal outcomes. The candidate passed both behavioral-parity cases and all five executable security cases. PATH-R01, PATH-R02, and PATH-R03 failed because missing, empty, and repeated filename inputs returned HTTP 404 instead of the registered HTTP 400 response; these are robustness-contract failures, not observed traversal attacks. PATH-S06 remains inconclusive because the Windows environment could not create the required symlink or junction fixture. Because three malformed-input contracts failed and symlink-escape protection remains unverified, I request more testing rather than reaffirming acceptance or claiming complete traversal protection. This later conclusion does not overwrite the original acceptance or primary metrics.

Traversal 04 · CWE-22 · primary-v1-path-traversal-initial-04

Primary target SAST: persistent; automated state: NEEDS_HUMAN_ADJUDICATION. Supplemental cases: 10 pass, 0 fail, 1 inconclusive. Nonpassing: PATH-S06 (inconclusive).

Primary decision: data/primary_trials/v1/cases/path-traversal/attempt-04/decision.json

Supplemental candidate result: data/supplemental/v1/runs/20260914T192827434537Z-candidates-path-traversal/attempt-04/result.json

Original primary human review — ACCEPT_CANDIDATE

Reviewer: Tony Tran · Recorded: 2026-09-12T20:04:51.060789Z

Source: data/primary_reviews/v1/primary-v1-path-traversal-initial-04/result.json

I reviewed the candidate patch and validation results. The candidate rejects empty and non-string file names, resolves the allowed root and requested path, and checks the resolved path against the root plus the platform path separator. This prevents parent traversal and sibling-prefix paths from being accepted. The recorded valid-file control and parent-traversal attack passed, all three functional tests passed, syntax passed, and no new SAST findings appeared. The CWE-22 warning remains at the path resolution operation, but it does not appear to account for the containment check that follows. I accept this candidate for the controlled /file route. Encoded inputs, repeated parameters, platform-specific variations, and symlink behavior remain limitations for supplemental testing.

Supplemental human review — FOLLOW_UP_REQUEST_MORE_TESTING

Reviewer: Tony Tran · Recorded: 2026-09-22T20:29:44.283383Z

Source: data/supplemental/v1/follow-up-reviews/primary-v1-path-traversal-initial-04/result.json

I reviewed the candidate patch, original acceptance, and all eleven supplemental traversal outcomes. The candidate passed both behavioral-parity cases, all three robustness cases, and all five executable security cases. PATH-S06 remains inconclusive because the Windows environment could not create the required symlink or junction fixture. The patch enforces a lexical resolved-root boundary, but the saved evidence does not establish containment of a filesystem target reached through an in-root link. I therefore request more testing in a symlink-capable environment rather than claiming complete traversal protection. This later conclusion preserves the original bounded acceptance, the inconclusive result, and all primary metrics.

Traversal 05 · CWE-22 · primary-v1-path-traversal-initial-05

Primary target SAST: persistent; automated state: NEEDS_HUMAN_ADJUDICATION. Supplemental cases: 9 pass, 1 fail, 1 inconclusive. Nonpassing: PATH-R03 (fail), PATH-S06 (inconclusive).

Primary decision: data/primary_trials/v1/cases/path-traversal/attempt-05/decision.json

Supplemental candidate result: data/supplemental/v1/runs/20260914T192827434537Z-candidates-path-traversal/attempt-05/result.json

Original primary human review — ACCEPT_CANDIDATE

Reviewer: Tony Tran · Recorded: 2026-09-12T20:10:48.803602Z

Source: data/primary_reviews/v1/primary-v1-path-traversal-initial-05/result.json

After reviewing the patch and results, I found that the candidate resolves the public-files root, adds the platform path separator as a directory boundary, and rejects a requested path unless it remains under that root. This blocks the recorded parent traversal and prevents a sibling path with a similar prefix from being accepted. The valid-file control and traversal attack passed, all three functional tests passed, syntax passed, and no new SAST findings appeared. The CWE-22 warning remains around path resolution, but it does not appear to account for the containment check that follows. I accept this candidate for the controlled /file fixture. The conversion with String(name || "") means missing, repeated, and unusual parameter values still deserve supplemental testing, along with encoded paths, platform variations, and symlink behavior.

Supplemental human review — FOLLOW_UP_REQUEST_MORE_TESTING

Reviewer: Tony Tran · Recorded: 2026-09-22T20:29:44.300579Z

Source: data/supplemental/v1/follow-up-reviews/primary-v1-path-traversal-initial-05/result.json

I reviewed the candidate patch, original acceptance, and all eleven supplemental traversal outcomes. The candidate passed both behavioral-parity cases, two of three robustness cases, and all five executable security cases. PATH-R03 supplied repeated filenames and returned HTTP 404 with a stable file-not-found response instead of the registered HTTP 400 response. The request exposed no outside content, so I treat this as a robustness-contract limitation rather than an observed traversal attack, and the failed result remains unchanged. PATH-S06 is also inconclusive because the Windows environment could not create the required symlink or junction fixture. I request more testing rather than claiming complete traversal protection. This later conclusion preserves the original acceptance and all primary metrics.

Evidence and interpretation boundary

This appendix was assembled from `data/evaluation/primary-report.json`, `data/supplemental/v1/supplemental-report.json`, ten bound primary review results, fourteen bound supplemental human results, and fifteen hash-checked supplemental candidate results. The generated appendix does not alter those files.

The main study concerns three deliberately vulnerable Express fixtures and repeated AI repair proposals, not fifteen independent applications or a representative web-app corpus. Passing registered tests does not establish production safety. A copied workspace preserves experiment inputs but is not a security sandbox.

The primary reviewer decisions were recorded at their original times. Supplemental human records apply later evidence without changing original primary states, reviews, or metrics. A bounded acceptance does not turn a robustness failure into a pass, and an inconclusive outcome stays inconclusive. For raw HTTP/browser observations, patches, scanner findings, or packet bindings, use the source paths in each candidate entry.